

APK Threat Analysis Platform with C2 Detection

India's digital payment system relies heavily on OTPs for security. Because hacking banks directly is incredibly difficult, scammers have found an easier target: the users themselves. They trick people into downloading fake apps (APKs) outside the official Google Play Store. These apps—often disguised as wedding invitations, electricity bill updates, or RTO traffic fines—silently steal OTPs from the victim's phone. As law enforcement tries to handle this growing issue, it's clear that manually checking every suspicious app takes too much time, allowing scammers to move the stolen money before they can be stopped.

1. The Problem in Karnataka Right Now

Recent events in Karnataka show how fast scammers are adapting. In April 2026, a massive scam in Belagavi used fake "Wedding Card" APKs. Victims downloaded the card, and without them doing anything else, the app hid itself, read their incoming bank OTPs, sent those OTPs to the scammer, and then deleted the SMS notifications so the victim wouldn't notice. People lost lakhs of rupees without realizing it until days later.

The state handles thousands of malware alerts daily. The core issue isn't that the CID lacks skilled officers; the problem is time. Taking apart a single fake app to figure out where it sends stolen data takes days of manual work. By the time investigators find the scammer's server (the Command and Control, or C2, server), the stolen money is gone.

2. Key Features Needed to Stop the Evasion

To actually solve this, a tool needs to counter the specific tricks scammers use to hide their tracks from standard police tools.

A. Detecting Hidden SMS Theft

These fake apps are designed to be invisible. They ask for permissions to read text messages, but they also include code that prevents the phone from showing a notification when a message arrives. If an officer looks at the victim's phone, they won't see the stolen OTPs. The tool needs a feature to automatically scan the app's code for these specific hiding techniques without running it.

B. Breaking Through Fake VPNs

Scammers know police try to monitor the network traffic of suspicious apps to see where the data goes. To block this, new malware creates its own hidden local VPN on the phone. This encrypts all the app's internet traffic. If an investigator uses standard network monitoring tools, they only see scrambled data, hiding the true IP address of the scammer's C2 server. The platform needs a feature that intercepts the data *before* it gets scrambled by the VPN.

The Main Goal: We need to stop reacting days after a crime happens. The CID needs an automated tool that can rip apart these fake apps instantly, find the scammer's server, and give officers actionable data in minutes instead of weeks.

3. How the Analysis Pipeline Works

Instead of building a flashy dashboard, this platform is a backend engine designed to process apps quickly using free, open-source tools. Here is the step-by-step workflow:

Step 1: Quick Code Scan (using Androguard)

When an officer uploads a suspicious APK, the system uses a Python tool called Androguard to unpack it. It immediately checks the app's permissions—flagging if it asks to read SMS or contacts without a good reason.

Step 2: Spotting Bad Behavior (using Quark Engine)

Next, the system scans the actual code using Quark Engine. It looks for specific patterns, like code that tries to read a text message and then immediately tries to delete the notification. If it finds this, it flags the app as highly dangerous.

Step 3: Extracting the Target Server (using Frida)

To beat the fake VPN trick, the system runs the app in an Android emulator. We use a tool called Frida to attach a script directly to the app while it runs. Right before the app tries to encrypt its data and hide its destination, the Frida script grabs the plain-text web address or IP of the scammer's server.

Step 4: Finding Other Targets

Once we have the scammer's server details (often a simple Telegram bot), the system can safely check that server to see if it's currently collecting OTPs from other phone numbers. This allows the police to warn those people before they lose money.

4. Why This Problem Matters Most

Solving this exact problem addresses the biggest bottleneck in cyber investigations right now. By automating the hardest parts of taking apart malware, this tool gives investigators the

speed they need to catch up. Instead of spending days figuring out how an app works, they get the scammer's server address in minutes, allowing them to block it and protect victims before the fraud happens.